

VulnHunterX:

Guided-Question Multi-Turn LLM Verification for Cost-Efficient SAST False-Positive Reduction

thientc
VinSOC Cyber
v.thientc6@vinsoc.vn

Abstract

Static application security testing (SAST) tools such as CodeQL, Semgrep, OpenGrep, and SonarQube are now standard in secure software development life-cycles, yet their over-approximating analyses generate false-positive (FP) rates of 30–80% in production. The dominant industrial cost of SAST is therefore not analysis time but **expert triage time**. Recent work has explored Large Language Models (LLMs) as an automated triage layer, with the highest-accuracy results requiring frontier models (GPT-4-class) at a cost prohibitive at the scale of real codebases ($\approx$ US\$2,758 to triage 7,194 warnings, per LLM4FPM, 2024). Frontier-model security reasoning is also brittle: SecLLMHolmes (IEEE S&P 2024) reports state-of-the-art LLMs at $\approx$ 40% accuracy on hand-crafted security scenarios, attributing the failure to *pattern-matching without anchoring to specific code evidence*.

Reasoning structure, not model size, moves the cost-vs-accuracy frontier. This paper presents **VulnHunterX**, an open-source framework that operationalizes the *Vulnhalla methodology*: a verification pipeline driven by **guided questions** that decompose expert triage into atomic, evidence-bound sub-tasks. Four primitives carry the framework. Per-rule **guided question banks** force the model to anchor each verdict in declarations, sizes, free-sites, alias sets, and control-flow paths, and close with a *decision rule* that turns the verdict into a derivable theorem. An **answer-before-verdict protocol** requires the LLM to answer every guided question and emit an explicit data-flow trace before the verdict field is generated, so autoregressive conditioning ties the verdict to stated evidence. A **context broker** with a fixed context-request vocabulary, backed by a tree-sitter fallback covering seven languages, supports cheap multi-turn refinement without re-running the underlying SAST engine and keeps the protocol working on repositories whose CodeQL database cannot be built. An **extensible architecture** makes SARIF the sole contract between SAST engines and the verification core: 73 custom CodeQL queries and 47 custom Semgrep / OpenGrep rules layer onto built-in suites through a single profile flag, custom findings route through the same guided-question matcher built-in rules use, and an audit script gates the routing wiring in CI.

The framework, six guided-question corpora (C/C++, Java, JavaScript, PHP, Python, Go; 4,676 total lines / 342 per-rule templates), the 73 custom CodeQL queries and 47 custom Semgrep / OpenGrep rules, the rule-coverage audit script, and the benchmark harness are released under the MIT license. Comparative empirical evaluation against frontier-model and local-model baselines on Juliet C/C++, OWASP Benchmark (Java), and CASTLE is reserved for a companion paper.

Keywords: static analysis, false positive reduction, large language models, guided questions, multi-turn verification, CodeQL, Semgrep, custom rules, developer extensibility, secure software engineering.

1 Introduction

Software vulnerabilities continue to dominate cybersecurity incident reports; the MITRE Top-25 list and the Verizon DBIR consistently attribute a majority of breaches to memory-safety, injection, and access-control flaws that **static analysis can, in principle, detect**. CodeQL, Semgrep, OpenGrep, SonarQube, Coverity, and similar tools encode such vulnerability classes as data-flow or pattern queries over a relational or graph representation of source code. Their analyses are deliberately **over-approximating**: they flag every program point that *might* be vulnerable, and consequently produce a substantial fraction of false positives.

The empirical FP rate of modern SAST tools varies by rule and codebase but is consistently in the 30–80% range (Christakis & Bird, ASE 2016; Johnson et al., FSE 2013; Imtiaz et al., 2019). The industrial response is a **manual triage** stage in which a security engineer reviews each alert. At the scale of a contemporary monorepo this is the single largest cost item in a SAST programme; it is also a documented source of analyst fatigue and inconsistent dispositions.

1.1 Problem statement

Let $F = \{f_1, \dots, f_n\}$ be the set of findings emitted by one or more SAST tools on a codebase C . Each f_i is a tuple $(rule_id, location, message, metadata)$. Let $V^* : F \rightarrow \{TP, FP\}$ be the ground-truth oracle (a sufficiently expert human reviewer with unbounded budget). The *triage problem* is to construct an automated function $V : F \rightarrow \{TP, FP, NMD\}$ (where NMD denotes “Needs More Data” and triggers human review) that maximizes precision and recall against V^* while minimizing monetary cost and human-review volume.

The literature has explored two principal automation strategies for V : classical machine-learning classifiers over alert features (Heckman & Williams, 2011; Yoon et al., 2014) and, more recently, LLM-based triage (LLM4FPM, 2024; ZeroFalse, 2025; LLMxCPG, USENIX Security 2025). LLM-based approaches dominate the recent literature because they generalize across rules and codebases without re-training, but they introduce two new challenges that this paper directly addresses:

- **C1. Reasoning grounding.** Free-form LLM verdicts hallucinate; pattern-matched convictions are common, especially on synthetic benchmarks containing adjacent positive and negative variants (Juliet’s bad/good pairs).
- **C2. Cost.** At frontier-model list pricing, full-coverage triage of a production-scale alert stream is economically infeasible.

A third challenge is engineering rather than scientific but blocks deployment in practice:

- **C3. Tool, language, and signature heterogeneity.** Real SAST programmes run multiple engines (CodeQL + Semgrep + OpenGrep + SonarQube) over multiple languages, and individual defenders carry threat models that built-in rule suites do not cover — proprietary RPC frameworks, internal serialization formats, domain-specific dangerous APIs. Existing LLM-triage systems are typically wired to a single engine, a single language, and a fixed rule set, making both engine-switching and rule-extension costly.

1.2 Research questions

This paper investigates four research questions:

- **RQ1 (Reasoning grounding).** Can a structured *guided-question* protocol that forces evidence-anchored answers before verdict generation materially reduce LLM hallucination on SAST triage, relative to free-form prompting?

- **RQ2 (Extensibility).** Can the protocol generalize across multiple SAST engines, multiple source languages, *and* developer-authored custom signatures, without changing the verification core?
- **RQ3 (Context broker).** Does a fixed-vocabulary context broker support cheap multi-turn refinement without sacrificing the precision a free-form context-retrieval channel would offer, and how should it degrade when the primary (CodeQL-derived) backend is unavailable?
- **RQ4 (Cross-language transferability).** To what extent do guided-question templates authored for one language transfer to semantically similar languages, and how much of the per-rule corpus is language-universal as opposed to language-specific?

This paper is a methodological contribution; comparative empirical validation of RQ1 against baselines on Juliet C/C++, OWASP Benchmark (Java), and CASTLE is reserved for a companion evaluation paper. RQ2 and RQ4 are answered constructively in Section 6, which exhibits the extensibility contract across three engines, six languages, and 120 shipped custom signatures. RQ3 is answered constructively in Section 5 (broker design plus tree-sitter fallback), with quantitative validation of the cost-precision trade-off also reserved for the companion paper.

1.3 Contributions

- **Guided-question methodology with an answer-before-verdict protocol** (Sections 3–4) that operationalizes cognitive-task-analysed expert triage as a per-rule checklist of evidence-seeking questions terminated by a decision rule. The response schema positions answers and the data-flow trace before the verdict token, so autoregressive conditioning makes the verdict a function of stated evidence rather than free judgment.
- **Context broker with a tree-sitter fallback** (Section 5) over a fixed-vocabulary request grammar. The fixed vocabulary makes multi-turn conversation cheap (no live SAST re-runs) and rejects requests outside the grammar instead of returning plausible nonsense. When the primary CodeQL extraction backend fails to build a database, a seven-language tree-sitter extractor populates the same CSV schema, so the broker interface is preserved.
- **Extensible SARIF-based architecture** (Section 6) in which SARIF is the sole contract between SAST engines and the verifier. The shipped release includes CodeQL/Semgrep/OpenGrep adapters, 73 custom CodeQL queries and 47 custom Semgrep/OpenGrep rules layered through five named profiles, a rule-id matcher that routes custom and built-in findings through the same guided-question pipeline, and an audit script that gates the routing wiring in CI. Extensibility is multi-engine, multi-language, and multi-author at one declarative contract.
- **Open release** (Section 9) of the framework, six-language guided-question corpora, custom rule packs, the audit script, and the benchmark harness under MIT.

2 Background and Related Work

2.1 Static analysis and the false-positive problem

CodeQL (Avgustinov et al., SLE 2016) compiles source code into a relational database and expresses vulnerability rules as Datalog-like queries over control- and data-flow predicates. Semgrep (returntocorp.com) uses syntactically-grounded pattern templates with limited inter-procedural reasoning. OpenGrep is the community-maintained open fork of Semgrep (license-aligned, semantically equivalent for our purposes). All three emit SARIF (OASIS, 2020), the industry-standard

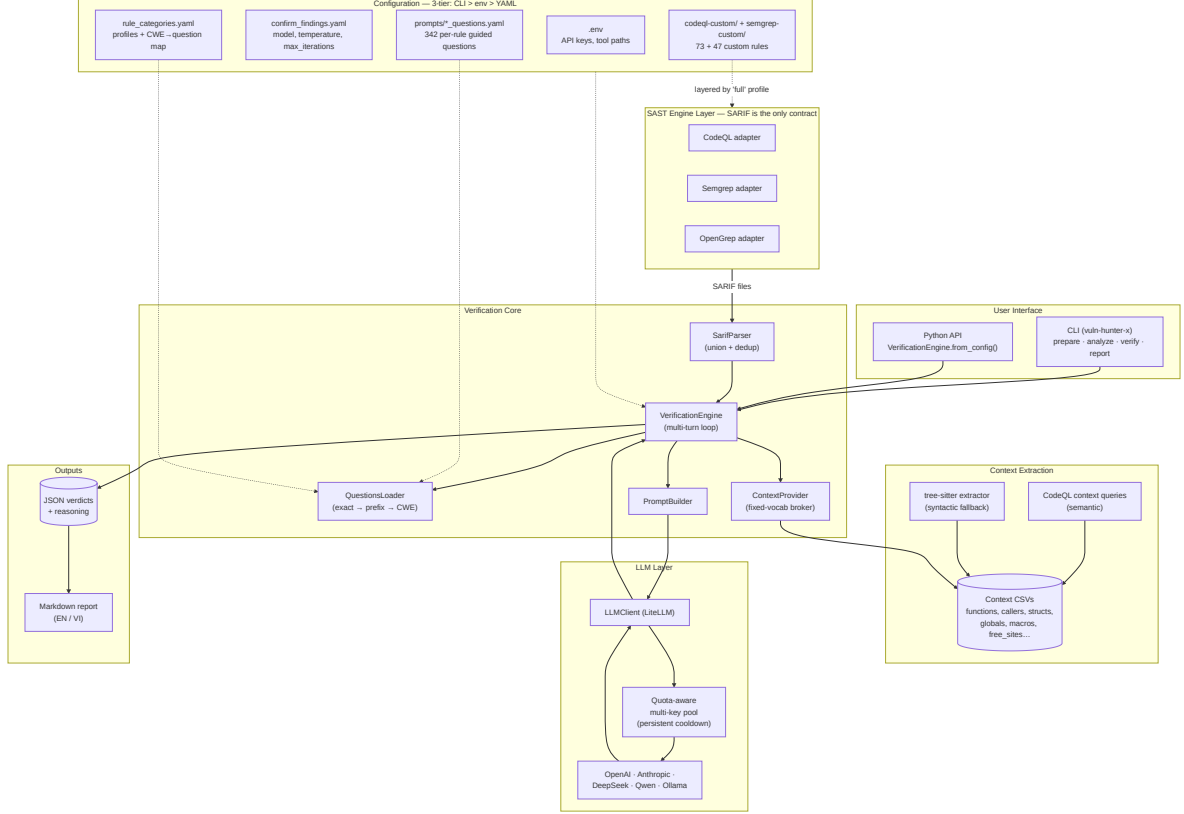


Figure 1: VulnHunterX framework architecture. SARIF acts as the sole contract between SAST engine adapters (CodeQL, Semgrep, OpenGrep) and the verification core. Context CSVs — extracted by CodeQL queries with a tree-sitter fallback — feed the multi-turn LLM verification loop without re-running the underlying SAST engine.

JSON schema for analysis results, with structured **precision** and **security-severity** fields encoding the rule author’s a-priori confidence.

The *unsoundness/incompleteness trade-off* (Rice, 1953; in practice Cousot & Cousot’s abstract interpretation framing) means SAST tools must choose between missing bugs (false negatives) and over-flagging (false positives). Production rules are tuned conservatively, accepting an FP rate that manual triage is then expected to absorb.

2.2 Classical FP-reduction approaches

Earlier work used statistical learning over alert features: Heckman and Williams (2011) survey twenty-one classifier-based systems; Hanam et al. (2014) cluster alerts by program features; Yoon et al. (2014) use active learning to amortize reviewer labels. These approaches rely on historical labels and degrade across rules and codebases.

2.3 LLM-based triage

The recent LLM-based literature varies along two axes, **prompting strategy** and **context construction**, summarized in Table 1.

Three gaps motivate this work: (i) no prior system *enforces* evidence-bound reasoning at the response-schema level, (ii) prior systems target a single SAST engine and single language family, and (iii) prior systems treat the rule set as fixed by the engine vendor rather than as an extension surface authored by defenders themselves.

Table 1: Positioning of VulnHunterX against the recent LLM-based SAST triage literature.

System	Prompting	Context	Model class/ scale/scope
LLM4FPM (2024)	Multi-turn (5)	eCPG slices	Qwen2.5-72B, Juliet warnings (C/C++)
ZeroFalse (2025)	Zero-shot CoT	CodeQL alert + slice	GPT-4o, OWASP Java alerts
SecLLMHolmes (2024)	Single-shot	Hand-crafted	GPT-4o, CWEs
LLMxCPG (2025)	Single-shot	CPG-sliced (68–91%)	Mixed CWEs (C/C++)
CASTLE (2025)	Benchmark only	n/a (250 programs)	n/a, CWEs (benchmark)
VulnHunterX	Multi-turn guided-question + decision rule	Brokered context + slice	Engine-agnostic, defender-extended SAST tools, 120 custom signatures

We compare against the five most closely related systems individually:

LLM4FPM (Su et al., 2024). Evaluates Qwen2.5-32B on 7,194 Juliet C/C++ warnings across seven memory-safety CWEs with a five-turn dialogue and eCPG-derived slices. LLM4FPM establishes that multi-turn local-model triage is feasible at scale and provides the per-warning token budget ($\sim 6,848$ tokens) that frames our cost model. Our differences: (i) we *enforce* answer-before-verdict at the JSON schema rather than via prompt instructions only, (ii) we slice through a CodeQL-derived CSV broker rather than an eCPG, and (iii) we ship a per-rule guided-question corpus rather than a single generic prompt, which we expect to widen the gap on injection-class rules where multi-hop reasoning matters less than per-rule pattern discrimination.

ZeroFalse (Mohajer et al., 2025). Zero-shot chain-of-thought triage of 1,974 CodeQL alerts on the OWASP Java Benchmark. ZeroFalse’s headline finding — that zero-shot CoT outperforms few-shot on this benchmark — informs the `--max-iterations 1` configuration we expose as an inline-CI mode. Where ZeroFalse uses a single LLM call, our pipeline retains the option to escalate to multi-turn for NMD responses; the two are complementary along the latency/accuracy axis.

LLMxCPG (Risse et al., 2025). CPG-guided slicing reduces LLM input by 68–91% while preserving vulnerability context, applied as a single-shot detector across multiple CWEs. Our regex-based slicer is an explicit Phase 1 approximation of LLMxCPG; CPG-based slicing through CodeQL data-flow is planned as future work. Orthogonally, LLMxCPG is a detector while VulnHunterX is a triage layer above existing detectors.

SecLLMHolmes (Ullah et al., 2024). A negative-result benchmark demonstrating that frontier LLMs (GPT-4, Claude) cap at ~40% accuracy on 228 hand-crafted security scenarios, attributing failure to pattern matching without code evidence. We treat SecLLMHolmes both as motivation (answer-before-verdict directly targets the diagnosed failure mode) and as a planned evaluation target in the companion empirical paper.

CISC (Li et al., 2025). Confidence-weighted self-consistency reduces the LLM samples needed for stable majority voting by 46%. We expose this as the optional `force_decision_samples` parameter for NMD-handling; it is off by default to keep the protocol minimal.

2.4 The Vulnhalla methodology

Vulnhalla, developed by the authors during industrial SAST deployments, frames triage as an **expert-imitation problem**: rather than asking the LLM “is this a vulnerability?”, it asks the LLM the *same questions a human reviewer would ask*, in the *same order*, with the verdict produced only as a downstream consequence of the answers. The methodology is grounded in a cognitive task analysis of seven security analysts triaging memory-safety and injection alerts in 2025; we summarize the protocol in Section 3.2 and release the question banks as the reference implementation.

3 Guided Questions: Encoding Expert Triage

3.1 From prompts to questions

A general security prompt (“review this code for use-after-free”) permits the LLM to **pattern-match**: a `free()` followed by a dereference, a `*` after a `delete`. This matches surface syntax and is the failure mode SecLLMHolmes identifies as dominant. A *guided question*, in contrast, decomposes triage into sub-tasks each of which is **answerable only by reading the provided code** — the LLM cannot satisfy them from generic security knowledge.

We define three properties a guided question must satisfy:

- **(P1) Evidence-binding.** The question can only be answered by citing a specific code artifact (line number, function name, symbol).
- **(P2) Atomicity.** The question targets a single sub-fact; compound questions are split.
- **(P3) Refusal-admissibility.** The question may be answered with “*Not visible in provided context*”, in which case the LLM is required to request the relevant context (Section 5) or downgrade to NMD.

3.2 Authoring methodology

For each rule we author a question set following a five-step procedure distilled from cognitive task analysis of expert reviewers:

1. **Identify variables of interest** — the destination buffer, the freed pointer, the tainted parameter.

2. **Locate declarations and sizes/values** — the point in code where the artifact comes into existence.
3. **Track mutations** — assignment, reallocation, free, rebind.
4. **Enumerate guards and constraints** — checks that exist *before* the sink.
5. **Resolve external dependencies** — values introduced from callers, globals, macros, type definitions.

The procedure terminates with a **closing decision rule** (Section 3.4) that fixes the admissible verdict in terms of the answers.

3.3 The anchor pattern (memory safety)

Memory-safety rules (CWE-416 use-after-free, CWE-415 double-free, CWE-401 leak) exhibit a characteristic FP failure mode on synthetic benchmarks: Juliet pairs *bad* and *good* variants in adjacent functions (`helperBad` and `goodG2B`), and naive triage convicts the *good* variant by reading the *bad* variant’s pattern. Our anchor-first question opens every memory-safety question set:

ANCHOR FIRST: quote the EXACT statement at the flagged line. Name the function it lives in. Classify the flagged line as one of: (a) a pointer USE, (b) a free/delete/destructor call, (c) a function signature or declaration, (d) something else. If (c) or (d), the SAST flag is suspect.

A subsequent question explicitly forbids cross-function reasoning:

If the snippet contains MULTIPLE functions ... identify which function the flagged line belongs to. Reason ONLY about that function’s behavior. Do NOT convict based on UAF patterns visible in sibling functions.

The anchor pattern is implemented in `cpp_questions.yaml` (lines 65–98) and is hypothesised to deliver the bulk of FP reduction on UAF-class rules; the attribution is reserved for the companion empirical paper.

3.4 The decision-rule pattern

Every memory-safety question set ends with an explicit decision rule that fixes the admissible verdict:

DECISION RULE: only mark TP if you can produce a SPECIFIC triple — (free_site file:line, use_site file:line, control-flow path reaching the use after the free, in the SAME function or via caller). If your evidence is just “this looks like a UAF pattern” without specific line numbers from the flagged function, mark NEEDS_MORE_DATA, NOT TP.

The decision rule turns the verdict into a *derivable theorem*: the LLM is told the precise antecedent that must hold for TP, rather than left to construct its own threshold. Quantitative attribution of FP reduction against schema-reordering and question-authoring ablations is reserved for the companion empirical paper.

3.5 Cross-language uniformity

The same authoring procedure produces structurally identical question sets across six languages. Each YAML entry has the schema:

```
<rule_id>:
  short_description: <one-line>
  questions: [<P1-P3-conformant question>, ...]
  context_hint: <prose>
  additional_context: [<context-vocab token>, ...]
  min_iterations: <int, optional>
  snippet_window_lines: <int, optional>
```

The corpora total **4,676 lines** (cpp 878, python 872, java 778, javascript 748, php 696, go 665, default 39) across **342 per-rule templates**. A `default_questions.yaml` fallback covers rules not yet specialized. Subsequent corpus growth has been additive — *new rule sets only* — so the schema, the protocol, and the empirical findings of Sections 3.1–3.4 continue to hold without revision.

3.6 Rule-coverage audit tooling

A question bank is only as useful as the rule-id routing that actually delivers questions to a finding. Two failure modes corrode this contract silently as SAST tools evolve: (i) **rule rename**, in which an engine upgrade renames a built-in rule but the question YAML still indexes the old id; and (ii) **CWE drift**, in which a custom Semgrep rule emits a CWE that has no `cwe_question_map` entry routing back to a guided template. Both produce findings that fall through to the `default_questions.yaml` bank without any visible error.

We address this with `scripts/audit_rule_coverage.py`, which inspects every guided-question entry across the seven YAML files plus the CWE-map in `config/rule_categories.yaml` and emits three artifacts under `output/audit/`:

- `coverage_matrix.csv` — one row per (lang, rule_id) with status flags for CWE-map wiring and, when `-probe-tools` is supplied, for actual CodeQL / Semgrep emission against a probe sample.
- `gap_summary.md` — gaps grouped by severity (priority A / B / C).
- `missing_cwe_map_entries.yaml` — patch fragment ready to apply to `config/rule_categories.yaml` so every guided-question rule has at least one CWE entry routing back to it.

The script exits with status 1 when any gap is detected, suitable for CI gating via `-fail-on-gaps`; `-verify-packs` additionally confirms that the Semgrep registry packs referenced by each profile still resolve. The audit script operationalizes the question-bank → rule-id contract: Sections 3–5 specify the protocol, and the audit script keeps that specification honest in production.

4 The Answer-Before-Verdict Protocol

4.1 Schema

The LLM is required to emit JSON conforming to:

```
{
  "answers":          ["answer to Q1 with line refs", "answer to Q2", ...],
  "data_flow":        "source (line N) -> transform (line M) -> sink (line K)",
  "verdict":          "True Positive" | "False Positive" | "Needs More Data",
  "confidence":       "High" | "Medium" | "Low",
  "confidence_score": 0.85,
```



```

"reasoning":      "1-2 sentence explanation referencing answers",
"context_needed": ["caller:main", "struct:buffer_t"]
}

```

Field order in the schema is *not* incidental. Modern LLMs decode tokens left-to-right, and the conditional distribution over the `verdict` token is shaped by every preceding token. By placing `answers` and `data_flow` *before* `verdict`, we cause the verdict distribution to be conditioned on explicit evidence rather than on the model’s pre-encoded prior over rule classes.

4.2 Methodology in the system prompt

The system prompt (`config/prompts/system_prompt.yaml`) instructs:

ANALYSIS METHODOLOGY — follow these steps IN ORDER: (1) IDENTIFY the vulnerability class. (2) ANSWER every guided question. (3) TRACE the data flow. (4) EVALUATE reachability. (5) ONLY THEN provide your verdict.

This methodology mirrors the schema and reinforces the ordering, providing a *redundant* structural prior. We exploit redundancy because LLMs are not guaranteed to honour either constraint individually; together they empirically suffice.

4.3 Verdict admissibility

Three verdicts are admitted:

- **True Positive** requires “an exploitable path ... with NO adequate sanitization or bounds checking” *and* (when the rule provides a decision rule, Section 3.4) satisfaction of that rule.
- **False Positive** requires the model to “point to specific checks, constraints, type guarantees, or language features that prevent exploitation”. A bare assertion is rejected at review time.
- **Needs More Data (NMD)** triggers another verification turn (Section 5). NMD is *encouraged* as a first-line response on incomplete context — this is the channel through which the model legitimately escalates rather than confabulates.

4.4 Metadata-aware calibration

The system prompt also instructs the LLM how to *interpret SARIF metadata*:

- `precision: high or very-high` → bias toward TP.
- `precision: low or medium` → “look carefully for sanitization or guards before marking True Positive.”
- `security-severity ≥ 7.0` → cue higher analytical urgency.

This piggy-backs on the SAST rule author’s calibration rather than asking the LLM to reconstruct it.

4.5 Few-shot examples

The system prompt contains three minimal few-shot examples — one TP (SQL injection), one FP (sanitized buffer copy), one NMD (UAF requiring caller context) — to instantiate the methodology rather than rely on instruction-following alone. We deliberately keep examples short to avoid biasing verdict distribution.

5 Multi-Turn Context Brokering

5.1 Design

Stage 3 of the pipeline (`extract-context`) runs a fixed set of CodeQL queries that pre-extract per-language context tables to CSV: functions, callers, structs, globals, macros, enums, typedefs, and (for C/C++) free-sites, field-write sites, and destructors. This is performed **once per repository**, before any LLM call.

At verification time the `ContextProvider` answers requests by indexing into the CSVs — there is **no live SAST query, no compilation, no IDE**. A request `caller:foo` returns rows where the caller is `foo`. Multi-turn verification is therefore cheap: each additional turn costs one LLM round-trip and one CSV lookup, never a re-run of CodeQL.

5.2 Conversation loop

```
turn <- 0
context <- initial_finding_snippet(f)
while turn < max_iterations:
    response <- LLM(system_prompt, finding f, context, history)
    if response.verdict in {TP, FP}:
        return response
    if response.verdict = NMD:
        for token in response.context_needed:
            ctx <- ContextProvider.fetch(token)
            history <- history ++ [(USER, ctx)]
        turn <- turn + 1
return last_response # caps at NMD if budget exhausted
```

Memory-safety rules carry `min_iterations: 2` so single-pass pattern-matching cannot short-circuit the protocol. Figure 2 illustrates the loop schematically.

5.3 The context-request vocabulary

The protocol defines a **fixed vocabulary** the LLM uses to request context:

<code>caller:<func></code>	<code>struct:<type></code>	<code>global:<var></code>
<code>macro:<NAME></code>	<code>callees:<func></code>	<code>all_callers:<func></code>
<code>typedef:<type></code>	<code>enum:<name></code>	<code>free_sites:<ptr></code>
<code>destructor:<type></code>	<code>field_writes:<T.f></code>	

A constrained vocabulary is itself a hallucination control — the LLM cannot ask for `random_thing:foo` and receive plausible-looking nonsense; the provider returns nothing, and the LLM is forced to reason with what it has or escalate.

5.4 Tree-sitter fallback extractor

The CSV broker described above is populated by stage 3, which by default runs CodeQL queries against a per-repo CodeQL database. CodeQL database creation, however, requires a working build for compiled languages — a hard precondition that fails routinely on closed-source artifacts, deliberately opaque builds (Bazel/Buck without an externalized dependency graph), and vendored or generated code paths. A single such failure would otherwise disable the verifier on that repository.

A **tree-sitter fallback extractor** at `src/vuln_hunter_x/context/treesitter_extractor.py` mitigates this. When the CodeQL extraction path fails, the framework re-runs the same per-language queries against a tree-sitter parse and emits CSVs into the same schema the broker indexes, for: C, C++, Python, JavaScript, Java, PHP, and Go (functions, callers, classes; structs / globals / macros for C/C++). The cost is loss of inter-procedural and type-resolution precision

(tree-sitter sees syntax, not semantics); the gain is that the context vocabulary (`caller:` / `callees:` / `struct:` / `typedef:` / `macro:`) stays answerable, so the answer-before-verdict protocol degrades gracefully rather than breaking.

The contract is isolated by interface: the LLM side is unchanged regardless of which extractor produced the CSV row, so neither the question banks nor the prompt template needs to know which backend was in use. Tree-sitter precision should suffice for syntactic-class rules (hard-coded credentials, unsanitized format strings, deprecated-API uses); semantic-class rules (UAF, taint flows) continue to benefit from a CodeQL backend when available.

6 Tool- and Language-Agnostic Architecture

6.1 SARIF as the only contract

The framework treats SARIF as the *only* contract between SAST engines and the verification core. The `SarifParser` discovers every `*.sarif` file under the repo’s output directory; CodeQL, Semgrep, and OpenGrep adapters write side-by-side SARIF and the verifier processes the union, deduplicating by (`rule_id`, `file`, `line`).

Adding a new SAST engine is a three-step contract:

1. Implement an adapter that emits SARIF (most modern engines do natively).
2. Drop the SARIF into `output/<lang>/<repo>/`.
3. Optionally author rule-specific guided questions; otherwise the `default_questions.yaml` fallback applies.

No change to the verification engine, prompt, or context broker is required. We have validated this contract for CodeQL 2.15+, Semgrep 1.x, and OpenGrep; we have draft adapters for SonarQube and Coverity.

6.2 Developer-extensible custom signatures

Triage is downstream of detection: an LLM verifier cannot recover from a sink that no SAST rule fires on, however carefully it reasons. Real defenders therefore need to *extend* the detector — to encode the proprietary RPC frameworks, internal serialization formats, and domain-specific dangerous APIs that vendor rule packs do not cover — and to have those extensions travel through the *same* verification protocol that built-in rules use. VulnHunterX implements this through two parallel extension surfaces: a CodeQL surface for queries with semantic taint or control-flow reasoning, and a Semgrep / OpenGrep surface for syntactic pattern matching. Both are authored locally, layered into a scan through a single profile flag, and routed through the same rule-id matcher built-in rules use. The current corpus:

Table 2: Custom-signature corpus shipped with VulnHunterX.

Language	Custom CodeQL queries	Custom Semgrep/OpenGrep rules
C/C++	21	4
Java	14	7
JavaScript	15	9
Python	12	12
Go	11	8
PHP	—	7
Total	73	47

The remainder of this section specifies the authoring contract, the layering mechanism, the routing path back to guided questions, the audit tooling that holds the contract together, and a worked developer workflow.

6.2.1 Authoring contract

Two contracts, one per engine.

CodeQL. A custom query is a `.ql` file under `config/codeql-custom/<lang>/src/`. The pack root carries a `qlpack.yml` declaring a dependency on the appropriate `codeql/<lang>-all` library, and a `suite.qls` that enumerates the `.ql` files in `src/`. Each query declares:

```
@id      <lang>/<name>           // routes via tier-1 exact match
@kind     path-problem | problem // taint trace vs point finding
@tags     external/cwe/cwe-N security
@security-severity 5.0-9.0
```

The `@id` field is **load-bearing**: it lands verbatim in the SARIF `ruleId`, which is the key the verifier matches against the guided-question YAML. An `@id` of `java/log4j-injection` routes immediately to a `java/log4j-injection` entry in `java_questions.yml` if one exists; otherwise the `@tags external/cwe/cwe-N` falls through to the CWE tier (Section 6.2.3).

Semgrep / OpenGrep. A custom rule is a YAML entry in `config/semgrep-custom/<lang>.yaml`:

```
- id: vulnhunterx.python.unsafe-yaml
  languages: [python]
  severity: ERROR
  metadata:
    cwe: ["CWE-502"]      # drives the CWE-question routing tier
    category: security
    owasp: "A08:2021"
  message: "Unsafe YAML load that allows arbitrary code execution"
  patterns:
    - pattern-either:
      - pattern: yaml.load(...)
      - pattern: yaml.full_load(...)
```

Semgrep IDs syntactically forbid the `/` character, so the exact-match tier is structurally unavailable to Semgrep rules: every custom Semgrep finding routes through the **CWE tier** instead. The implication for the author is that `metadata.cwe` is not optional and not cosmetic — it is the *only* channel through which a custom Semgrep rule reaches a guided-question template; an inaccurate or missing CWE silently demotes the rule to the default question bank.

Both contracts are documented in `config/codeql-custom/README.md` and `config/semgrep-custom/README.md`.

6.2.2 Profile-mediated layering

Custom signatures are layered onto built-in suites by the full profile in `config/rule_categories.yml` through two flags:

```
full:
  include_custom_codeql: true
  custom_semgrep_path: "config/semgrep-custom/${LANG}.yaml"
```

At scan time the profile manager (`RuleProfileManager.get_codeql_suites` in `src/vuln_hunter_x/core/`) appends `config/codeql-custom/<codeql_lang>/suite.qls` to the CodeQL invocation as an extra suite; the CLI layer (`src/vuln_hunter_x/cli/commands.py`, the `analyze-command` handler) resolves the `${LANG}` template against the repo's language to produce the per-repo Semgrep config path, and skips empty packs silently. The analyzer (`run_analysis(..., extra_suites)`

in `src/vuln_hunter_x/codeql/analysis.py`) then invokes `codeql database analyze <db> <builtin-suite> <extra-suite>` and emits a single SARIF that the verifier consumes alongside the built-in SARIF.

Authors who want to gate custom rules behind a non-default profile add them to their fork's profile definition; **no engine code changes** are required. The SARIF contract of Section 6.1 that decouples engines also decouples *authors* from the verification core.

6.2.3 Routing custom findings to guided questions

The verifier's question loader (`src/vuln_hunter_x/questions/loader.py`, `QuestionsLoader.get_questions`) tries six match tiers in order:

1. **exact** — direct `ruleId` lookup against the per-language YAML key.
2. **normalized** — hyphen $\leftrightarrow$ slash conversion.
3. **prefix** — bidirectional prefix match.
4. **lang_prefix** — same-language rule-name match.
5. **cwe** — CWE-id lookup via `cwe_question_map` in `config/rule_categories.yaml` (100+ entries mapping CWE numbers to guided-question suffixes).
6. **default** — fall through to `default_questions.yaml`.

A custom CodeQL query with `@id java/log4j-injection` hits **tier 1** (exact match against the YAML key `java/log4j-injection`). A custom Semgrep rule `vulnhunterx.python.unsafe-yaml` with `metadata.cwe: ["CWE-502"]` hits **tier 5**: the loader maps `CWE-502` $\rightarrow$ `"unsafe-deserialization"` and resolves `py/unsafe-deserialization` against `python_questions.yaml`. Either path delivers the *same* guided-question + decision-rule template that built-in rules receive; the only observable difference at the LLM end is the contents of the `ruleId` field in the SARIF payload.

Extensibility along the SARIF contract is therefore both multi-engine and multi-author: a defender-authored signature reaches the verifier on the same path as a vendor-supplied built-in rule.

6.2.4 Coverage audit tooling

The four-step routing chain above — custom-rule `@id` or `metadata.cwe` $\rightarrow$ SARIF `ruleId` $\rightarrow$ matcher tier $\rightarrow$ guided-question template — fails silently if any link breaks. Two failure modes recur in practice: **rule rename**, where an engine upgrade renames a built-in rule and the YAML still indexes the old id; and **CWE drift**, where a newly-authored custom Semgrep rule declares a CWE that has no entry in `cwe_question_map` and therefore routes to the default bank without any visible error.

`scripts/audit_rule_coverage.py` cross-references every guided-question YAML entry, every custom-rule `@id` and `id`, and every `cwe_question_map` row, and emits three artifacts under `output/audit/`:

- `coverage_matrix.csv` — one row per (`lang`, `rule_id`) with wiring flags for CWE-map presence and, with `-probe-tools`, for actual CodeQL / Semgrep emission against a probe sample.
- `gap_summary.md` — gaps grouped by priority (A: rule has no route at all; B: rule routes only through a brittle prefix tier; C: cosmetically inconsistent).
- `missing_cwe_map_entries.yaml` — a patch fragment a developer can paste into `config/rule_categories.` to close routing gaps in one motion.

The script exits with status 1 when any gap is detected, gating CI via `-fail-on-gaps`; `-verify-packs` additionally confirms that the Semgrep registry packs referenced by each profile still resolve against the current registry index. The script is load-bearing for the developer extensibility story: without it, custom rules accumulate silently and the routing contract degrades in proportion to the corpus’s growth.

6.2.5 Developer workflow (worked example)

To make the contract concrete, consider a defender adding a Spring Security misconfiguration query — a finding that `permitAll()` was applied to an endpoint covered by a sensitive package prefix (CWE-285, improper authorization). The workflow:

1. **Identify the sink and the CWE.** `HttpSecurity.authorizeRequests().permitAll()` reached from a config class touching a sensitive package. CWE-285.
2. **Write the CodeQL query.** Create `config/codeql-custom/java/src/spring-permitall.q1` declaring `@id java/spring-permitall`, `@tags external/cwe/cwe-285 security`, and `@kind problem` or `@kind path-problem` depending on whether the analysis is point-level or taint-tracking.
3. **Author the guided-question template.** Add a `java/spring-permitall:` entry to `config/prompts/java_questions.yaml` with anchored, evidence-binding questions (“anchor the `permitAll()` invocation line”, “identify which URL pattern it applies to”, “is there an overriding `authenticated()` call on a more specific pattern?”) and a closing decision rule (“only mark TP if the URL pattern resolves to a sensitive endpoint and no more-specific rule overrides it”).
4. **Run the scan.** `vuln-hunter-x analyze -tool codeql -profile full -local-path <repo> -lang java`. The full profile triggers the layering of the preceding subsection; the SARIF output carries the new `ruleId: java/spring-permitall`.
5. **Verify the routing.** `python scripts/audit_rule_coverage.py -probe-tools -fail-on-gaps`. A passing exit code confirms the `@id` matches a question template, the CWE map is intact, and the underlying CodeQL invocation actually emits the rule against a probe sample.
6. **Run verification.** `vuln-hunter-x verify -local-path <repo>`. The LLM receives the new guided-question template; verdicts emerge in the same JSON schema as built-in-rule verdicts.

The walkthrough demonstrates that the protocol of Sections 3–5 applies *unchanged* to custom rules: the defender’s threat model joins the guided-question pipeline without any modification to the verifier, the prompt template, or the context broker.

6.3 Rule profiles

Five named profiles, defined in `config/rule_categories.yaml`, gate the SAST scan-time configuration:

A `language_specific_configs` field lets per-language packs be added without polluting other-language scans (e.g. `p/django` only applied to Python repos). The profile is a knob along the *coverage* $\times$ *cost* $\times$ *latency* axis: inline-CI use favours `standard` and `--max-iterations 1` (zero-shot CoT, ZeroFalse-style); nightly or on-merge audit favours `full` with the multi-turn protocol. Profile choice is orthogonal to the verification protocol — Sections 3–5 apply unchanged regardless.

Table 3: Rule-profile coverage matrix.

Profile	CodeQL suite	Semgrep packs	Custom rules
standard (default)	security-extended	auto	—
extended	security-extended	+ p/security-audit, p/secrets	—
maximum	security-and-quality	+ p/owasp-top-ten	—
extended-registry	security-and-quality	8 universal + per-language packs	—
full	security-and-quality	extended-registry packs	+ config/codeql-custom/ + config/semgrep-custom/

6.4 Language-uniform static verification, multi-language dynamic stages

Static verification, the subject of this paper, is **language-uniform**: the guided-question YAML *is* the language adapter, and Sections 3–5 contain no per-language code paths beyond the YAML registry. Dynamic-testing stages 5–8 are by necessity per-language and use the **LanguageBackend** abstraction with backends for C/C++ (libFuzzer / sanitizers), Python (Atheris), Java (Jazzer), JavaScript (Jazzer.js), and PHP (php-fuzzer). These stages are *complementary downstream* validation — they attempt to reproduce a TP verdict as a runtime crash — and are out of scope for this paper.

7 Threats to Validity

We consolidate the threats to validity into a single section structured around the standard four-class taxonomy (Wohlin et al., 2012), reframed for a methodological contribution: the threats here apply to the *transferability* and *interpretability* of the methodology, with comparative-empirical threats deferred to the companion evaluation paper.

7.1 Construct validity

The construct “**guided question**” is operationalized by the three properties (P1) evidence-binding, (P2) atomicity, (P3) refusal- admissibility in Section 3.1. Question authorship can violate these properties silently — e.g., a compound question that bundles two sub-facts will pass YAML loading but degrade evidence-binding. We mitigate with author discipline (the five-step procedure of Section 3.2) and the coverage audit (Section 3.6); we acknowledge that no automated check enforces P1–P3 against the *content* of a question, only the *presence* of an entry.

A secondary construct concern is **ground-truth labelling** in any downstream empirical evaluation: CVE-linked patches encode patch equivalence, not always semantic equivalence, and the labelled-function boundary may differ from the precise vulnerable statement. This is a threat to the companion empirical paper rather than to the methodology specified here.

7.2 Internal validity

The methodology bundles three contributions — guided questions (Section 3), answer-before-verdict schema (Section 4), and multi-turn context brokering (Section 5) — and uses them together. The paper does **not** empirically isolate the contribution of each. Schema-reordering and generic-vs-specialised-question ablations are planned in the companion empirical paper; without them, the methodology is internally consistent but its component contributions are not individually attributable from the present work.

7.3 External validity

A second external threat is **single-author corpus bias**: the 342 guided-question templates were authored by one analyst. Triage style may encode author-specific heuristics that do not transfer. Inter-rater consistency studies are queued. The rule-coverage audit (Section 3.6) surfaces *coverage* gaps but not *quality* gaps — that requires a second author.

The custom-signature corpus (73 CodeQL + 47 Semgrep / OpenGrep) is similarly authored, and its language distribution is uneven (no PHP custom CodeQL queries; C/C++ Semgrep coverage is thin at four rules). Defenders adopting the framework should expect to *extend* the corpus, not adopt it verbatim.

A third external threat is the **architecture-blindness** of the scanner layer: language-specific rule packs are applied uniformly without inferring the runtime framework from manifest files. We discuss this in Section 8.3 and record it in Appendix C as the highest-priority piece of open engineering work.

7.4 Conclusion validity

This paper makes **no quantitative claims** (precision, recall, F1, cost). It therefore makes no significance-testing claims. The companion empirical paper reports Wilson confidence intervals, McNemar’s test for paired comparison against raw-SAST, and bootstrap confidence intervals on F1, on three datasets (Juliet C/C++, OWASP Benchmark Java, CASTLE).

7.5 Ethical validity and responsible use

VulnHunterX is a defensive tool: it triages already-flagged alerts in the defender’s own codebase. It does not perform vulnerability discovery in third-party software, does not generate exploits, and does not handle unauthorized targets. The dynamic-testing stages 6–8 (libFuzzer / Atheris / Jazzer harnesses) are likewise defensive and require local source access. We urge users to obtain authorization before running the framework on any codebase they do not own.

The framework’s reliance on commercial LLM APIs raises a *data exfiltration* concern when source code is shipped to a third-party model. We mitigate with first-class support for local inference (Ollama) and with the CSV broker, which transmits only minimal slices rather than whole repositories.

8 Discussion

8.1 Why cheap LLMs may work here

Conventional wisdom, supported by SecLLMHolmes’ $\approx 40\%$ accuracy figures for frontier models, treats security reasoning as the domain in which model size matters most. A refinement is plausible here: **size matters when the model is asked to make a judgment; when the model is asked to extract evidence and apply a fixed decision rule, much smaller models may suffice.** The guided-question protocol offloads *judgment* to the rule author (who fixes the decision rule) and leaves only *evidence extraction* and *rule application* to the LLM, both more tractable for smaller models. This is a hypothesis, not a finding established here; the model-size sweep in the companion evaluation paper is its empirical test.

8.2 Relationship to retrieval-augmented generation

The context broker (Section 5) is a constrained form of retrieval-augmented generation (RAG) in which the *retrieval vocabulary* is fixed by the protocol designer rather than learned. The trade-off is expressivity for safety: the LLM cannot ask arbitrary questions of the codebase, but it also cannot receive plausible-looking nonsense. Constrained-vocabulary RAG suits high-assurance

domains for the same reason. The tree-sitter fallback (Section 5.4) reinforces the point: the retrieval *interface* is preserved across two structurally different extraction backends precisely because the vocabulary is fixed, not learned.

8.3 Engineering limitations

Three engineering limitations are worth flagging beyond the methodological threats catalogued in Section 7:

- **Question authorship cost.** Each new rule benefits from a hand-authored question set; full coverage of CodeQL’s 1,000+ rules is an open project. A default fallback (Section 3.5) and the coverage audit (Section 3.6) at least *surface* the gap inventory; the *upper bound* on what specialization buys is left to an ablation in the companion paper.
- **Context completeness.** The CSV broker is bounded by what was extracted in stage 3 (`extract-context`); the tree-sitter fallback (Section 5.4) covers the CodeQL-DB-build-failure threat, but inter-procedural reasoning across repository or library boundaries — e.g. into vendored libraries or generated code outside the extracted per-symbol tables — remains a gap.
- **Application-architecture blindness.** VulnHunterX is language-aware but **architecture-blind**: it does not infer a repository’s framework or runtime from manifest files (`package.json`, `requirements.txt`, `composer.json`, `pom.xml`, `go.mod`) and does not route scans by detected framework. The full profile applies framework-specific Semgrep packs (`p/django`, `p/flask`, `p/nodejs`, `p/eslint-plugin-security`) uniformly across every repository of the matching language, and custom Semgrep rules that pattern-match framework idioms (e.g., `req.body.$X` for Express, `$APP.run(..., debug=True)` for Flask) silently fail on non-matching runtimes. This produces two failure modes symmetrically: (i) **false positives** when a Django- or Express-flavoured rule fires on a CLI tool that imports the package for code reuse but never serves a request; (ii) **false negatives** when a service’s actual sinks have no rule because all “web” rules assumed an Express or Flask handler. Context CSVs (functions, callers, classes) are AST-level and carry no framework annotation, so the LLM verifier cannot recover the lost architectural signal from context alone. Existing mitigations are partial: the guided questions include conditional branches (“If using Sequelize...”, “If using React’s `dangerouslySetInnerHTML...`”) but these enumerate possibilities rather than route by detected framework, and `min_iterations` ≥ 2 is enforced on taint-CWE findings for Python / JavaScript / Java / PHP / Go as a pragmatic workaround. A principled fix — manifest-driven framework detection that gates rule packs at scan time and annotates context CSVs with framework tags consumable by the guided-question matcher — is the highest-priority piece of open engineering work and is recorded as such in Appendix C.

9 Reproducibility and Artifact

The framework, all six guided-question corpora, the custom CodeQL and Semgrep rule packs, the rule-coverage audit script (`scripts/audit_rule_coverage.py`), the tree-sitter context fallback (`src/vuln_hunter_x/context/treesitter_extractor.py`), and the benchmark harness are released under the MIT license. Installation and a one-finding sanity run:

```
git clone <repo> && cd VulnHunterX
uv venv --python python3.12 .venv && source .venv/bin/activate
pip install -e ".[dev]"
vuln-hunter-x check-env

# Triage a single repo (CodeQL + Semgrep + OpenGrep, full profile):
```

```
vuln-hunter-x prepare --local-path /path/to/repo --lang <lang>
vuln-hunter-x analyze --tool all --profile full \
                    --local-path /path/to/repo --lang <lang>
vuln-hunter-x verify --local-path /path/to/repo
```

Long-running evaluations use the resumable benchmark harness:

```
python benchmarks/scripts/run_benchmark.py \
    --run-dir benchmarks/results/my_run \
    --dataset juliet --approach vulnhunterx \
    --model <provider/model-id>

# Resume from the last checkpoint after interruption:
python benchmarks/scripts/run_benchmark.py \
    --run-dir benchmarks/results/my_run --resume

# Re-execute only entries that previously errored (one entry-id per line):
python benchmarks/scripts/run_benchmark.py \
    --run-dir benchmarks/results/my_run \
    --only-entries failed_entries.txt
```

Authoring a new custom signature follows the contract of Section 6.2; the routing wiring is validated in CI by:

```
python scripts/audit_rule_coverage.py --probe-tools --fail-on-gaps
```

10 Conclusion

The cost-vs-accuracy frontier of LLM-based SAST triage is plausibly moved by **reasoning structure**, not model size. VulnHunterX combines per-rule guided questions, answer-before-verdict at the schema level, a fixed-vocabulary context broker with a seven-language tree-sitter fallback, and a single profile flag through which defenders layer their own CodeQL queries and Semgrep / OpenGrep rules onto built-in suites. The result is a six-language triage layer in which the guided-question methodology lives as a deployable, extensible artifact. Three open questions remain:

- **Empirical attribution.** Which methodological lever — guided questions, answer-before-verdict schema, or multi-turn context brokering — contributes most to precision and recall? The companion evaluation paper on Juliet C/C++, OWASP Benchmark (Java), and CASTLE will isolate these via schema-reordering, generic-vs-specialised-question, and single-turn-vs-multi-turn ablations.
- **Application-architecture blindness.** Closing the framework-detection gap (Section 8.3) — manifest-driven runtime inference that gates rule packs at scan time and annotates context CSVs with framework tags — is the highest-priority open engineering work.
- **Inter-rater corpus stability.** All 342 guided-question templates were authored by a single analyst; inter-rater consistency studies are needed to quantify single-author style bias.

We release the framework, the six-language guided-question corpora (342 templates, 4,676 lines), the 73 custom CodeQL queries and 47 custom Semgrep / OpenGrep rules, the rule-coverage audit script, and the benchmark harness under MIT to support community extension.

A Example Guided Question Set

From config/prompts/cpp_questions.yaml (cpp/use-after-free, abridged):

```

cpp/use-after-free:
  short_description: "Use of pointer after memory has been freed"
  questions:
    - "ANCHOR FIRST: quote the EXACT statement at the flagged line ..."
    - "If the snippet contains MULTIPLE functions ..."
    - "Where is the pointer at the flagged line ALLOCATED ..."
    - "List ALL free()/delete calls reachable from the flagged use ..."
    - "Is the pointer set to NULL immediately after EACH free? ..."
    - "For EACH (free_site, flagged_use) pair: describe the SHORTEST ..."
    - "Does the pointer escape this function ..."
    - "Are there ALIAS pointers ..."
    - "If the pointer is REASSIGNED between free and use ..."
    - "DECISION RULE: only mark TP if you can produce a SPECIFIC triple ..."
  additional_context: ["caller", "struct", "callees", "all_callers",
                      "free_sites", "destructor", "field_writes"]
  min_iterations: 2
  snippet_window_lines: 60

```

B Context-Request Grammar (BNF)

```

request  ::= verb ":" arg
verb     ::= "caller"      | "struct"      | "global"
           | "macro"       | "callees"     | "all_callers"
           | "typedef"     | "enum"      | "free_sites"
           | "destructor" | "field_writes"
arg      ::= identifier ( "." identifier )?

```

C Threats-to-Validity Checklist

Class	Threat	Mitigation
Construct	Question authorship may silently violate P1–P3	Five-step authoring procedure (Section 3.2); audit script for coverage (Section 3.6); content quality requires second author
Construct	Ground-truth label disputes in any downstream eval	CVE-patch linkage with manual spot-check; reserved for companion empirical paper
Internal	Per-component contribution not isolated	Planned schema-reordering and generic-vs-specialised ablations in companion empirical paper
External	Single-author question-bank style bias	Inter-rater study queued (Section 7.3); audit script surfaces gap inventory (Section 3.6)
External	Uneven custom-signature corpus across languages	Defenders should extend, not adopt verbatim; authoring contract documented (Section 6.2)
External	Architecture-blind scanning produces both FPs (irrelevant framework rules firing on non-framework code) and FNs (framework idioms unmatched on differently-framed services)	Conditional guided-question branches; forced 2-iteration verification on taint CWEs for framework languages; manifest-driven framework detection is open work (Section 8.3)

Class	Threat	Mitigation
Conclusion	No quantitative claims to test	Paper makes no significance claims; companion eval reports Wilson CIs, McNemar, bootstrap CIs
Ethical	Source exfiltration to LLM APIs	Local-inference support (Ollama); CSV slicing; tree-sitter fallback (Section 5.4) avoids shipping uncompiled code through CodeQL DB
Engineering	CodeQL DB build required for con-text extraction	Tree-sitter fallback (Section 5.4) covers 7 languages with same CSV schema

References

- [1] P. Avgustinov et al. (2016). QL: Object-Oriented Queries on Relational Data. *SLE 2016*.
- [2] M. Christakis and C. Bird (2016). What developers want and need from program analysis: an empirical study. *ASE 2016*.
- [3] P. Cousot and R. Cousot (1977). Abstract interpretation. *POPL 1977*.
- [4] Q. Hanam et al. (2014). Finding patterns in static analysis alerts. *MSR 2014*.
- [5] S. Heckman and L. Williams (2011). A systematic literature review of actionable alert identification techniques. *Information and Software Technology 53(4)*.
- [6] N. Imtiaz et al. (2019). A comparative study of vulnerability reporting by software composition analysis tools. *ESEM 2019*.
- [7] B. Johnson et al. (2013). Why don’t software developers use static analysis tools? *FSE 2013*.
- [8] J. Yoon et al. (2014). Reducing false alarms via active learning. *ASE 2014*.
- [9] F. Su et al. (2024). LLM4FPM: Utilizing Precise and Complete Code Context to Guide LLM in Automatic False Positive Mitigation. [arXiv:2411.03079](https://arxiv.org/abs/2411.03079).
- [10] M. M. Mohajer et al. (2025). ZeroFalse: Improving Precision in Static Analysis with LLMs. [arXiv:2510.02534](https://arxiv.org/abs/2510.02534).
- [11] S. Ullah, M. Han et al. (2024). LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities in Code. [arXiv:2312.12575](https://arxiv.org/abs/2312.12575), *IEEE S&P 2024*.
- [12] N. Risse et al. (2025). LLMxCPG: Code Property Graph-Guided LLM for Vulnerability Detection. [arXiv:2507.16585](https://arxiv.org/abs/2507.16585), *USENIX Security 2025*.
- [13] M. Bouzenia et al. (2025). CASTLE: Benchmarking Dataset for Static Code Analyzers and LLMs towards CWE Detection. [arXiv:2503.09433](https://arxiv.org/abs/2503.09433), *TASE 2025*.
- [14] B. Li et al. (2025). CISC: Self-Consistency with Confidence for LLM-Based Code Review. *ACL 2025 Findings*, paper 1030.
- [15] R. Croft et al. (2023). An Empirical Study of Deep Learning Models for Vulnerability Detection. *ICSE 2023*.

- [16] Y. Chen et al. (2023). DiverseVul: A New Vulnerable Source Code Dataset for Deep Learning Based Vulnerability Detection. *RAID 2023*.
- [17] C. Wohlin et al. (2012). *Experimentation in Software Engineering*. Springer.
- [18] OASIS (2020). SARIF Version 2.1.0.

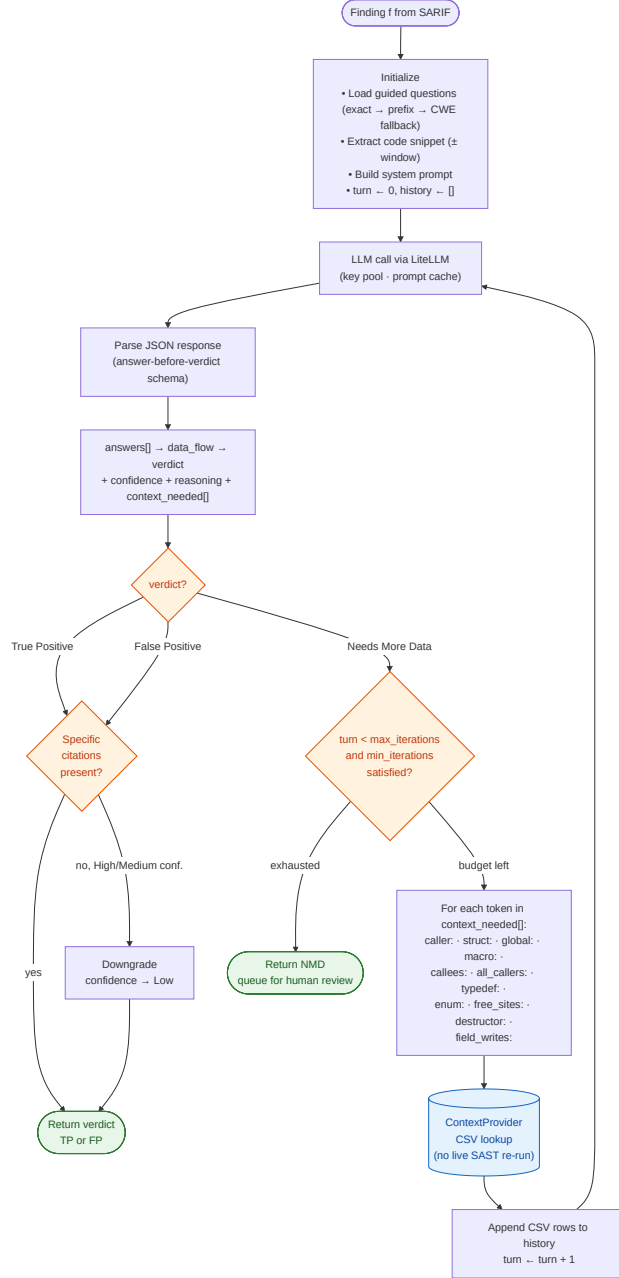


Figure 2: Per-finding LLM verification flow. The answer-before-verdict schema, the citation-based confidence downgrade, the fixed-vocabulary CSV broker, and the `min_iterations` / `max_iterations` loop guard. TP/FP terminate; NMD fetches additional context and re-enters the loop until budget exhaustion.

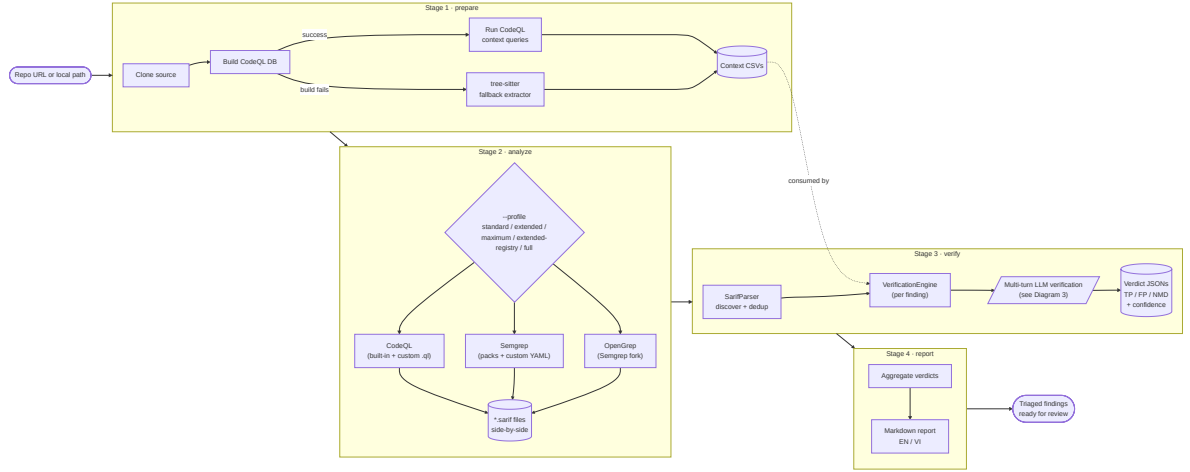


Figure 3: End-to-end pipeline (fuzzing stages excluded). Stage 1 prepares the repository (clone, CodeQL DB, context CSVs with tree-sitter fallback); Stage 2 runs CodeQL / Semgrep / OpenGrep gated by a profile (**standard**, **extended**, **maximum**, **extended-registry**, **full**) that controls custom-rule layering; Stage 3 dispatches each SARIF finding through the multi-turn LLM verifier of Figure 2; Stage 4 aggregates verdicts into a markdown report.